

Sprawozdanie z laboratorium: podstuch i analiza ruchu MQTT



Wykonał: Maciej Niemiec

Numer albumu: 107162

1. Wprowadzenie

MQTT (Message Queuing Telemetry Transport) to lekki, tekstowy protokół komunikacyjny typu *publish/subscribe*. Został zaprojektowany dla urządzeń IoT oraz sensorów o małej mocy i korzysta z transportu TCP/IP. W architekturze MQTT występują dwa typy uczestników:

- **broker** (serwer) pośredniczący w wymianie wiadomości
- **klienci** publikujący komunikaty na określonych tematach (topics) bądź je subskrybujący.

Tematy są zorganizowane hierarchicznie, co ułatwia grupowanie danych (np. dom/kuchnia/temperatura).

Protokół definiuje kilka poziomów jakości dostarczania wiadomości (QoS):

- 0 – at most once (bez potwierdzeń),
- 1 – at least once (możliwe duplikaty),
- 2 – exactly once (najbezpieczniejszy, lecz obciążający).

Do zalet MQTT należą bardzo mały narzut (nagłówek min. 2 bajty), możliwość przechowywania ostatniej wiadomości przez brokera (retained messages) oraz obsługa mechanizmu LWT (Last Will and Testament) umożliwiającego informowanie o „śmierci” klienta. Protokół jest powszechnie wykorzystywany w rozwiązaniach inteligentnego domu, teledyktacji, komunikacji M2M i wszędzie tam, gdzie ważna jest oszczędność energii.

Domyślnie MQTT przesyła dane w postaci niezaszyfrowanej - bezpieczeństwo jest proste i często nie stosuje się szyfrowania. W praktyce zaleca się korzystanie z wersji protokołu *MQTT over TLS* na porcie 8883, z uwierzytelnianiem (login/hasło, certyfikaty, listy ACL). W niniejszym laboratorium zbadano, jak łatwo można podsłuchać niezaszyfrowany ruch MQTT przy pomocy Wiresharka oraz w jaki sposób szyfrowanie TLS uniemożliwia odczytanie treści.

2. Część laboratoryjna

Konfiguracja połączenia MQTT Explorer

Do analizy wykorzystano aplikację **MQTT Explorer**. Na początku utworzono nowe połączenie z publicznym brokerem test.mosquitto.org na porcie **1883** (bez szyfrowania). W oknie konfiguracji pozostawiono domyślny identyfikator klienta i nie zaznaczano opcji SSL/TLS, zgodnie z instrukcją.

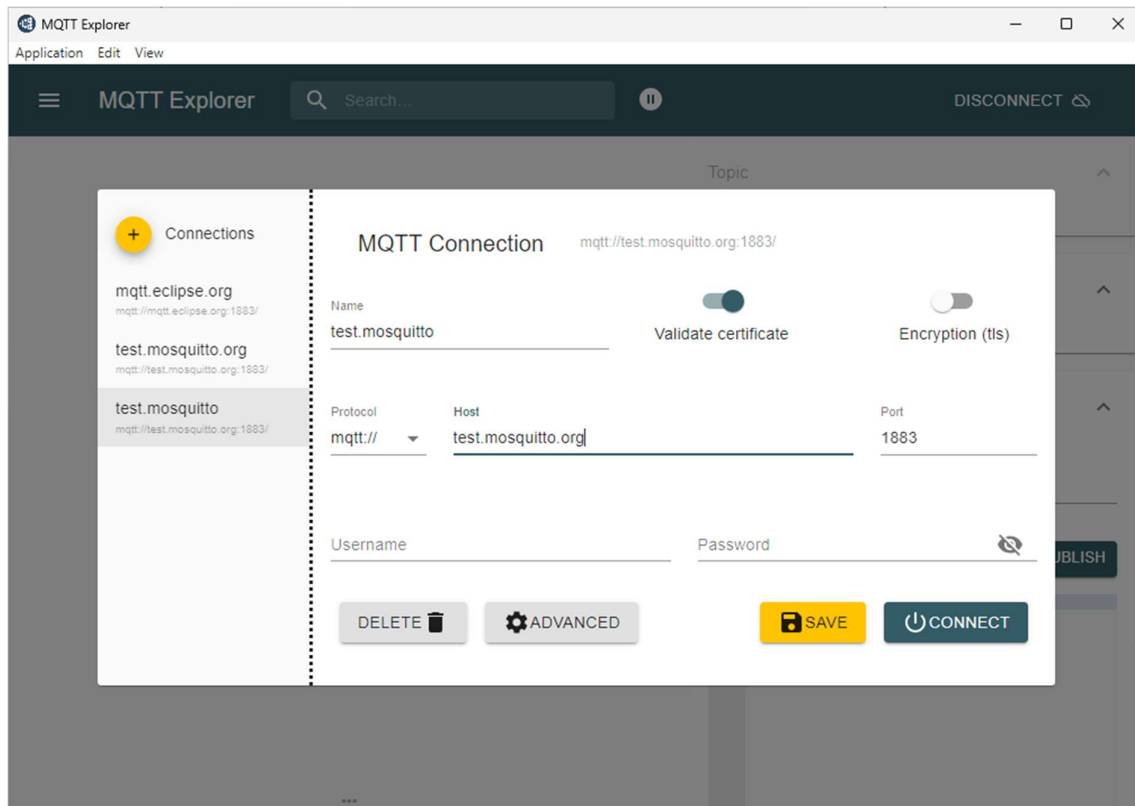


Figure 1 - przedstawia okno konfiguracji aplikacji.

Po zapisaniu ustawień i kliknięciu **CONNECT** aplikacja wyświetliła drzewo istniejących tematów na brokerze. W polu wyszukiwania wpisano własny temat lab/iot/grupa5 i zasubskrybowano go.

Publikacja i subskrypcja wiadomości

W panelu **Publish** wprowadzono wartość lab/iot/grupa5 w polu *Topic*, wybrano format *raw* i wpisano treść temp=22.5. Naciśnięcie przycisku **PUBLISH** spowodowało przesłanie wiadomości. Po lewej stronie, w drzewie tematów, pojawiła się ścieżka lab/iot/grupa5, a wartość temp=22.5 została wyświetlona, co oznacza, że subskrypcja działa poprawnie.

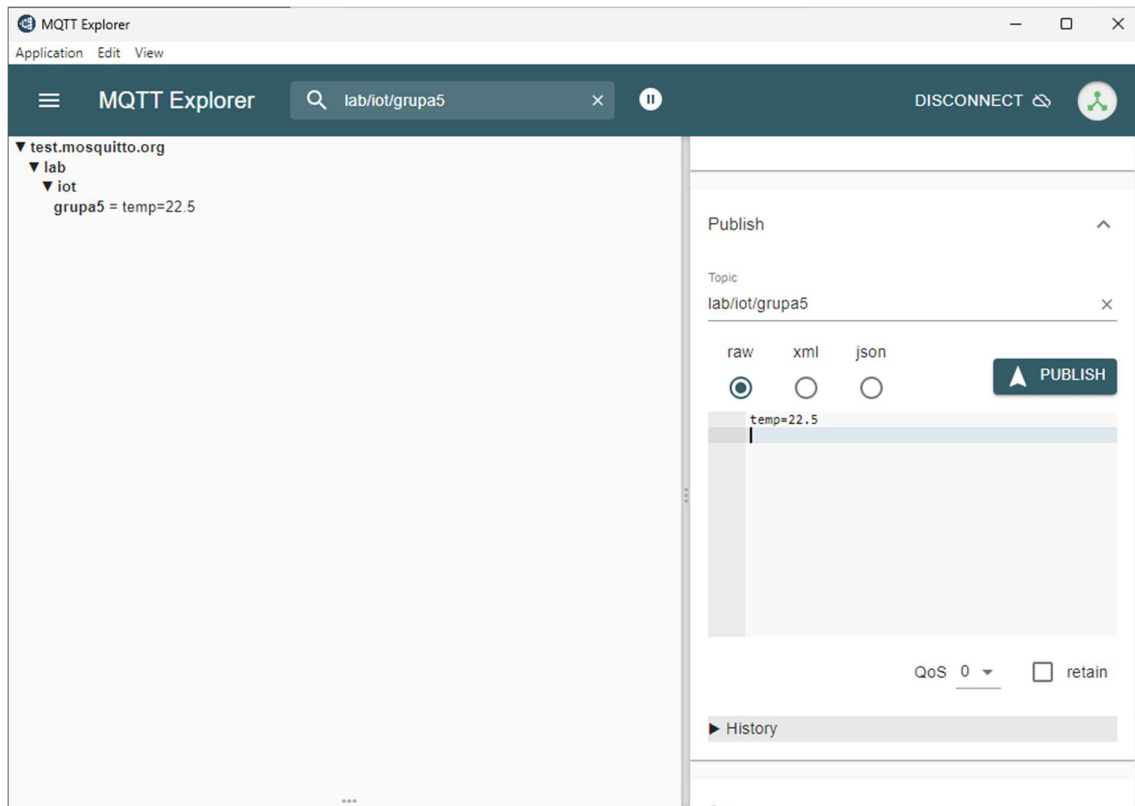


Figure 2 - publikowanie wiadomości

Następnie do tego samego tematu wysłano ciąg o charakterze wrażliwym („super tajna wiadomość bez szyfrowania”), a także kilka dodatkowych wartości. W historii publikacji aplikacji widać kolejne wiadomości, co potwierdza poprawność wymiany danych.

Podśluch ruchu MQTT w Wiresharku

Wireshark uruchomiono na interfejsie, przez który komputer łączył się z Internetem. W filtrze wyświetlania zastosowano wyrażenie `mqtt`, aby pokazywać tylko ramki MQTT. Po wysłaniu wiadomości w MQTT Explorerze widoczne są nowe pakiety typu **Publish Message**. Kliknięcie jednego z pakietów pozwala w dolnym panelu przeanalizować nagłówki protokołu MQ Telemetry Transport (MQTT). W sekcji „Topic Name” znajduje się pełna nazwa tematu `lab/iot/grupa5`, a w polu **Message** widnieje treść przesłanej wiadomości (w tym przypadku `temp=22.5`). Oznacza to, że dane są przesyłane jako zwykły tekst.

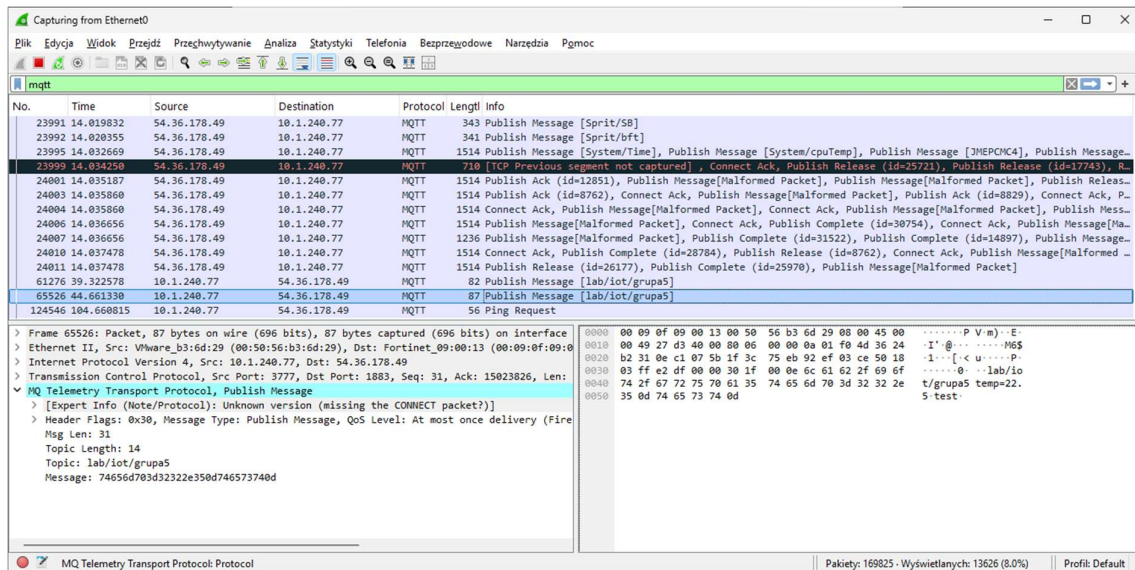


Figure 3 - podgląd niezasyfrowanej wiadomości w Wiresharku.

Wysłanie „super tajnej” wiadomości spowodowało, że w zrzucie pakietów pojawił się tekst zawierający pełną treść („super tajna wiadomość bez szyfrowania”). Analiza heksadecymalna w dolnym panelu Wiresharka ujawniła, że cały ładunek można łatwo odczytać, co potwierdza, że brak szyfrowania naraża transmisję na podsłuch.

Szyfrowanie TLS

Aby zwiększyć bezpieczeństwo, skonfigurowano nowe połączenie w MQTT Explorerze z tym samym brokerem, ale port zmieniono na **8883** i włączono opcję SSL/TLS. Po połączeniu i zasubskrybowaniu tego samego tematu wysłano kilka wiadomości, jak wcześniej. W Wiresharku filtr zmieniono na `tcp.port == 8883`. Narzędzie wyświetliło pakiety TLS 1.2 z zakodowaną zawartością. W odróżnieniu od wcześniejszej sytuacji, analizując pakiet nie widzieliśmy już pól **Topic Name** ani **Message** - cały ładunek był zaszyfrowany.

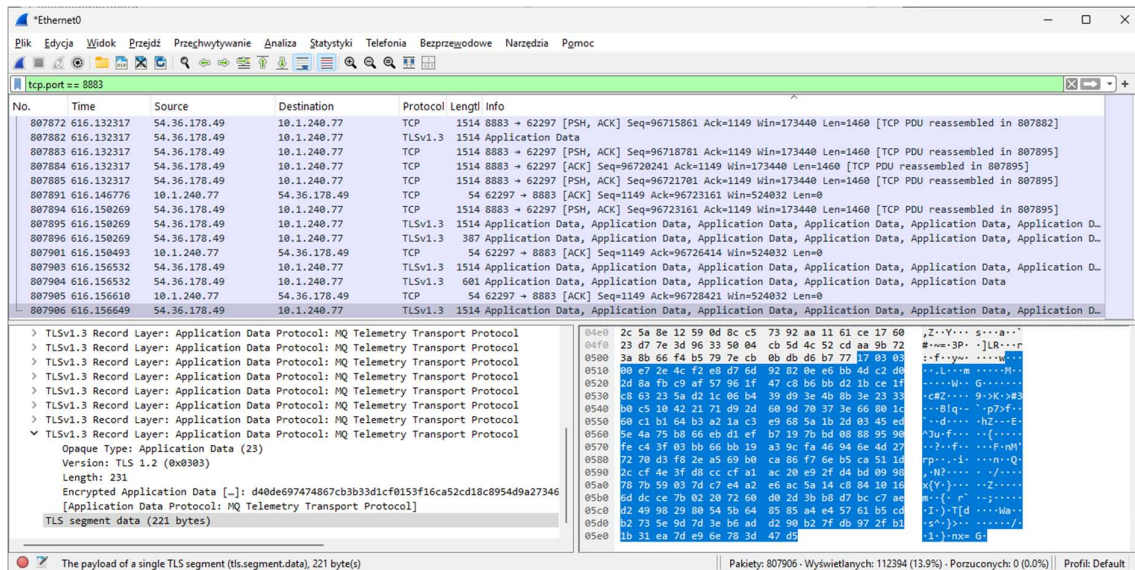


Figure 4 - dane przesyłane po TLS są nierozpoznawalne.

3. Wnioski

Wykonane ćwiczenia potwierdzają, że MQTT jest lekkim i efektywnym protokołem do komunikacji w systemach IoT, jednak domyślnie nie zapewnia poufności przesyłanych danych. Analiza pakietów w Wiresharku bez TLS ujawnia zarówno pełną nazwę tematu, jak i treść wiadomości. Wystanie wrażliwego tekstu („super tajna wiadomość”) pokazuje, że każdy podsłuchujący w sieci lokalnej może łatwo odczytać przesyłane informacje. Dopiero włączenie szyfrowania TLS na porcie 8883 powoduje, że ładunki MQTT są zaszyfrowane i nie da się z nich odczytać tematu ani wartości. Z tego względu przy projektowaniu rozwiązań IoT korzystających z MQTT należy zawsze stosować wersję protokołu z TLS oraz zadbać o uwierzytelnianie użytkowników.